

[LOGO AREA]

AMMAR ALZAIEM

CYBERSECURITY | VAPT

SECURITY ASSESSMENT REPORT

Mini Web Assessment – Task 29

REPORT ID	AZ-WEB-2026-029
VERSION	1.0
ASSESSMENT DATE	29/9/2026
REPORT DATE	29/9/2026
PREPARED BY	Ammar Alzaiem
CLASSIFICATION	Public

I used DVWA lab through out this task

First I gathered some information about the target using recon tools

Nmap

```
(ammar@noOne)-[~]
$ nmap -sV 192.168.56.2
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-29 11:10 +03
Nmap scan report for 192.168.56.2
Host is up (0.00023s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet         Linux telnetd
25/tcp    open  smtp           Postfix smtpd
53/tcp    open  domain         ISC BIND 9.4.2
80/tcp    open  http           Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind        2 (RPC #100000)
139/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec           netkit-rsh rshcd
513/tcp   open  login          OpenBSD or Solaris rlogind
514/tcp   open  shell          Netkit rshd
1099/tcp  open  java-rmi       GNU Classpath grmiregistry
1524/tcp  open  bindshell      Metasploitable root shell
2049/tcp  open  nfs            2-4 (RPC #100003)
2121/tcp  open  ftp           ProFTPD 1.3.1
3306/tcp  open  mysql          MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql     PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc            VNC (protocol 3.3)
6000/tcp  open  x11            (access denied)
6667/tcp  open  irc            UnrealIRCd
8009/tcp  open  ajp13          Apache Jserv (Protocol v1.3)
8180/tcp  open  http          Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:CB:51:F5 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.96 seconds
```

Is shows some services running on the host with version information

Gobuster

```
(ammar@noOne)-[~]
$ gobuster dir -u http://192.168.56.2/dvwa -w /usr/share/wordlists/dirbuster/directory-list-1.0.txt -s "200,301,302" -b ""

Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.56.2/dvwa
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-1.0.txt
[+] Status codes: 200,301,302
[+] User Agent: gobuster/3.6
[+] Timeout: 10s

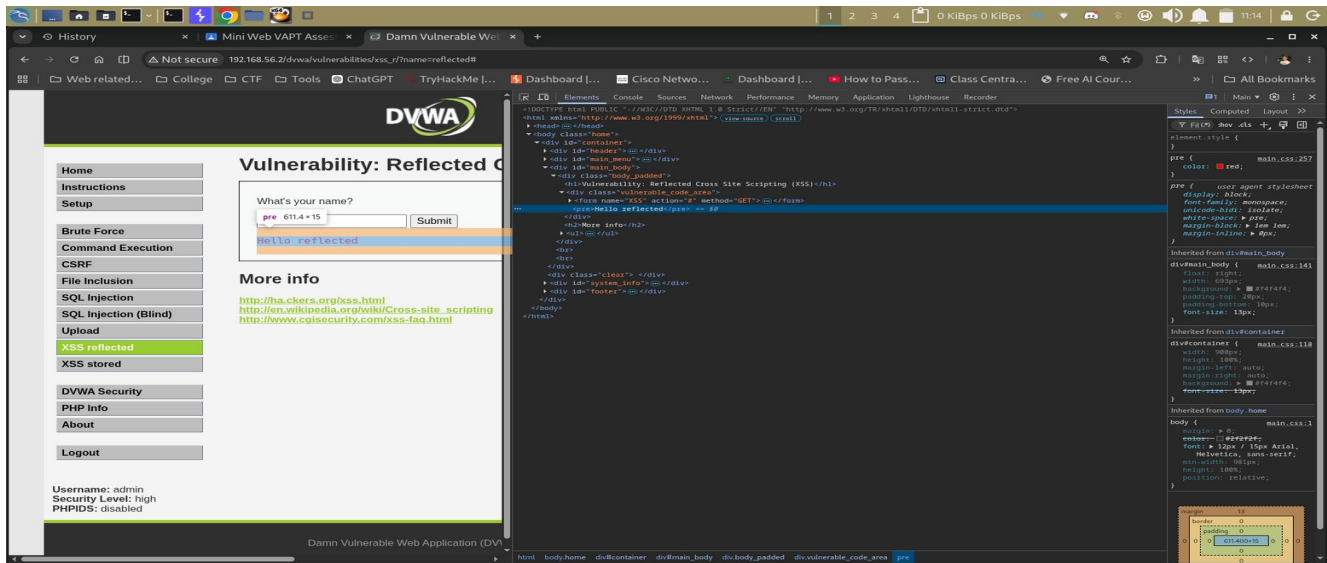
Starting gobuster in directory enumeration mode

/about (Status: 302) [Size: 0] [→ login.php]
/index (Status: 302) [Size: 0] [→ login.php]
/docs (Status: 301) [Size: 321] [→ http://192.168.56.2/dvwa/docs/]
/robots (Status: 200) [Size: 26]
/security (Status: 302) [Size: 0] [→ login.php]
/login (Status: 200) [Size: 1289]
/config (Status: 301) [Size: 323] [→ http://192.168.56.2/dvwa/config/]
/external (Status: 301) [Size: 325] [→ http://192.168.56.2/dvwa/external/]
/setup (Status: 200) [Size: 3549]
/logout (Status: 302) [Size: 0] [→ login.php]
/vulnerabilities (Status: 301) [Size: 332] [→ http://192.168.56.2/dvwa/vulnerabilities/]
/instructions (Status: 302) [Size: 0] [→ login.php]
/favicon (Status: 200) [Size: 1406]
/COPYING (Status: 200) [Size: 33107]
Progress: 141708 / 141709 (100.00%)

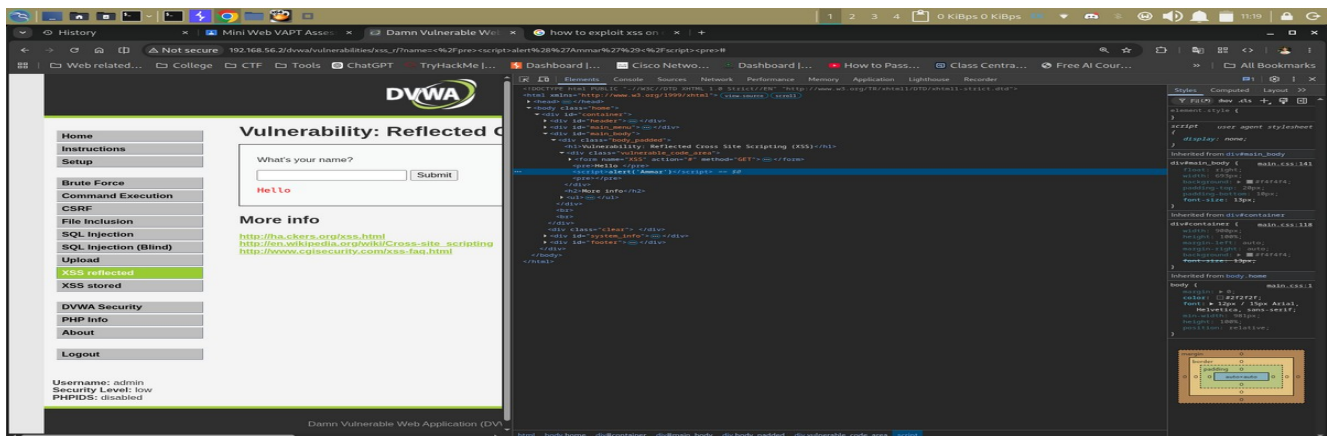
Finished
```

This output mapped some important endpoints.

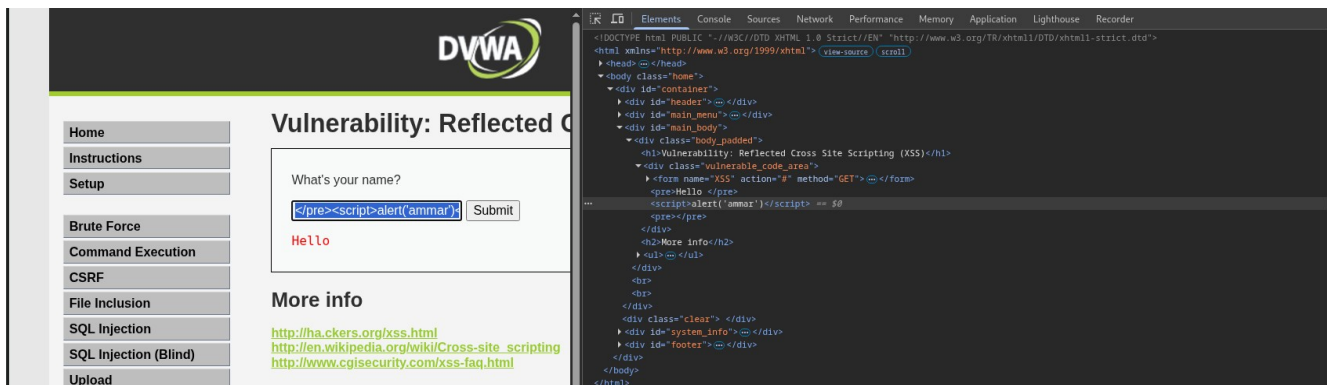
XSS exploitation



First I checked where my input is getting reflected. Then I constructed the corresponding payload to POC

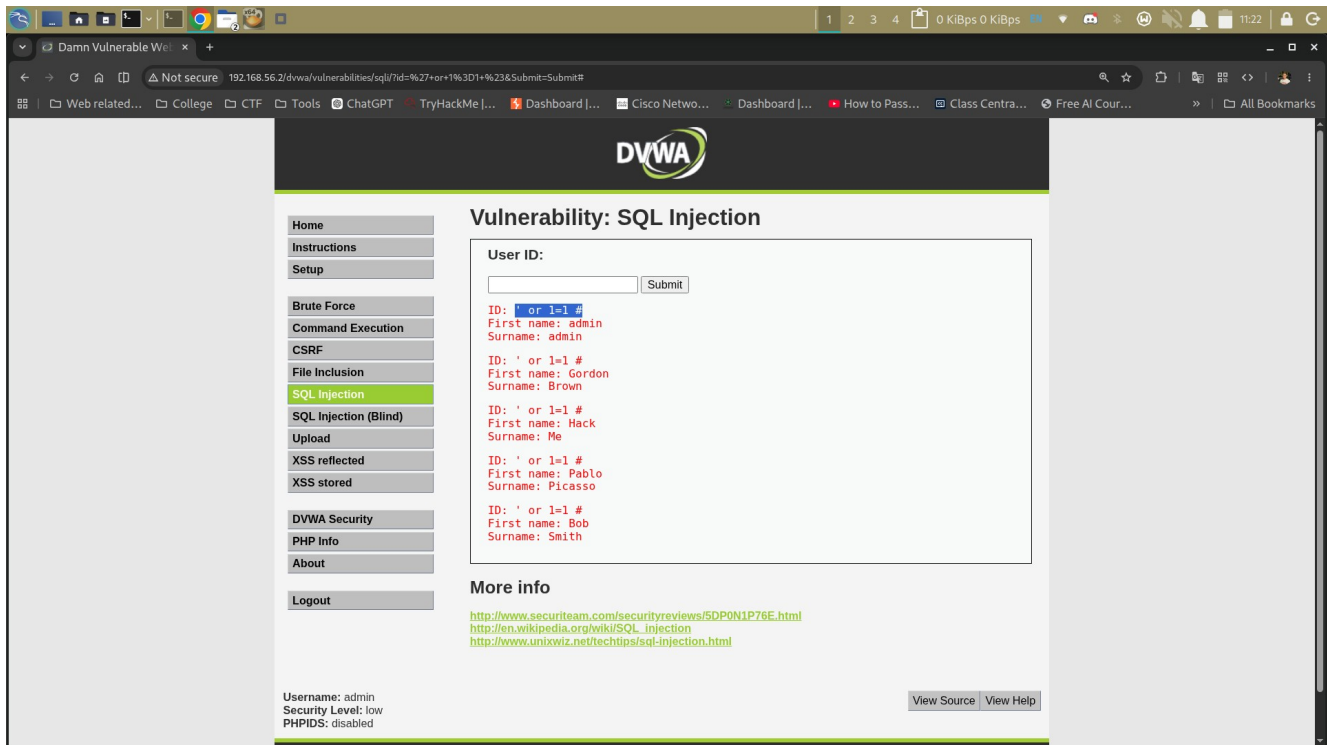


I used `</pre><script>alert('ammар')</script><pre>`



SQL Injection Exploitation

First I tested if the parameter was vulnerable to SQLi, via '**OR 1=1 #**' and it returned true



So I tried to extract credentials from the users table, via **Union select username, password from users #**

